

IDENTITY & ACCESS MANAGEMENT

ACCESS CONTROL AUDIT REPORT

TechNova Inc.

Confidential — Internal Use Only

Audit Date	June 2025
Prepared By	IAM Analyst — TechNova Internal Audit
Classification	Confidential — Internal Use Only
Scope	25 employees across 6 departments and 6 systems
Frameworks	ISO 27001, SOC 2, GDPR, PCI-DSS

1. Executive Summary

This report presents the findings of an Identity and Access Management (IAM) audit conducted for TechNova Inc. in June 2025. The audit reviewed access entitlements for 25 employees across 6 departments and 6 business systems, assessing compliance with the Principle of Least Privilege, Role-Based Access Control policy, Segregation of Duties requirements, and access review obligations.

The audit identified 12 findings across four risk categories. Immediate action is required on three Critical findings, two of which involve active accounts belonging to terminated employees and one which presents a direct financial fraud risk.

1.1 Summary of Findings

Critical	High	Medium	Low
3	6	3	0

1.2 Key Risks Identified

- Two orphaned accounts belonging to terminated employees remain active, one with live AWS Admin access over 12 months post-termination.
- A Finance employee holds Admin-level payment system access with no secondary approver, creating a direct Segregation of Duties conflict and financial fraud risk.
- Multiple junior and intern-level staff hold Admin or elevated access to critical systems including CoreBanking and AWS, violating the Principle of Least Privilege.
- Access review cadence is non-compliant with ISO 27001 and SOC 2 requirements for two employees, representing a formal compliance gap.
- A Marketing Intern holds Read/Write access to the HR Portal, creating a potential GDPR data minimisation violation.

1.3 Immediate Actions Required

The following three actions must be completed within 24-48 hours of this report being issued:

Priority	Action	Finding
1	Disable all accounts for Kevin Okafor (TN-011) and Yuki Tanaka (TN-022) immediately	AF-001, AF-002 — Orphaned Accounts
1	Downgrade CoreBanking access for Rohan Desai (TN-021) to Read Only and implement payment approval controls	AF-003 — Segregation of Duties Conflict
1	Rotate all AWS credentials and review CloudTrail logs for post-termination activity	AF-002 — AWS Credential Exposure

2. Audit Scope and Methodology

2.1 Scope

This audit covered the complete user access entitlement register for TechNova Inc. as of June 2025. The following were included in scope:

In Scope	Out of Scope
• All 25 active and terminated employees • 6 business systems: CoreBanking, HR Portal, GitHub Enterprise, AWS Console, Jira, Slack • 6 departments: Engineering, Finance, HR, Management, Marketing, Sales, IT Support • Access review history and last review dates	• Technical penetration testing • System configuration reviews • Third-party vendor access • Physical access controls

2.2 Methodology

The audit was conducted using the following approach:

- User Access Register Review: A complete review of all 25 user entitlement records was performed, cross-referencing job titles, departments, and system access levels.
- Policy Compliance Check: Each user's access was assessed against TechNova's stated access control policy, the Principle of Least Privilege, and RBAC requirements.
- Violation Identification: Findings were identified by comparing actual access against expected access for each role, flagging deviations, orphaned accounts, SoD conflicts, and overdue reviews.
- Risk Rating: Each finding was rated using a four-tier risk scale (Critical, High, Medium, Low) based on potential business and security impact.
- Framework Alignment: Findings were mapped against ISO 27001, SOC 2 Type II, GDPR, and PCI-DSS requirements where applicable.

3. IAM Policy Framework

The following IAM principles formed the basis of this audit. All access decisions at TechNova Inc. should be governed by these standards.

Principle	Definition and Audit Application
Principle of Least Privilege (PoLP)	Every user should have only the minimum access required to perform their job function. No access should be granted beyond operational necessity. Violations identified in AF-005, AF-006, AF-007, AF-012.
Role-Based Access Control (RBAC)	Access entitlements are assigned based on a user's job role, not individually. All users in the same role should have a consistent and defined access profile. Underpins all 12 findings.
Segregation of Duties (SoD)	No individual should hold permissions that allow them to both initiate and authorise a sensitive action without oversight. Critical in financial and payment contexts. Violation identified in AF-003.
Orphaned Account Management	All accounts belonging to terminated employees must be disabled on or before the employee's last working day. Failure to do so creates an active unauthorised access risk. Violations in AF-001, AF-002.
Privilege Creep Prevention	When a user changes roles, their prior access entitlements must be reviewed and revoked before new entitlements are granted. Violation identified in AF-004.
Access Review Cadence	All user access entitlements must be formally reviewed at least once every 12 months, and within 90 days of joining for new hires. Compliance gaps identified in AF-010, AF-011.

4. Detailed Findings

The following 12 findings were identified during this audit. Each finding includes the affected employee, systems involved, a description of the violation, and a specific recommended remediation action.

4.1 Critical Findings — Immediate Action Required

AF-001	Orphaned Account	Critical	Open	TN-011
Employee: Kevin Okafor — Developer, Engineering Systems Affected: CoreBanking, GitHub Enterprise, AWS Console, Jira, Slack Description: Employee terminated on 2023-11-30 but all system accounts remain active as of audit date. Active credentials for a terminated employee represent an unauthorised access risk and a potential insider threat vector. Recommended Action: Disable all accounts immediately. Review access logs for any post-termination activity. Implement a formal offboarding checklist to prevent recurrence.				
AF-002	Orphaned Account	Critical	Open	TN-022
Employee: Yuki Tanaka — Developer, Engineering Systems Affected: GitHub Enterprise, AWS Console, Jira, Slack Description: Employee terminated 2023-02-28. Account remains active over 12 months post-termination with AWS Console Admin access still live. This is the highest severity orphaned account in this audit due to active cloud infrastructure exposure. Recommended Action: Disable all accounts immediately. Rotate all AWS credentials. Review CloudTrail logs for activity post 2023-02-28. Escalate to CISO for formal review.				
AF-003	Segregation of Duties Conflict	Critical	Open	TN-021
Employee: Rohan Desai — Accounts Payable, Finance Systems Affected: CoreBanking Description: Holds Admin-level CoreBanking access in an Accounts Payable role, granting ability to both initiate and approve payment transactions without a second authoriser. This is a direct SoD violation and financial fraud risk that would fail a SOC 2 or PCI-DSS audit. Recommended Action: Downgrade CoreBanking to Read Only immediately. Enforce a four-eyes principle for all transactions above a defined threshold. Review transaction history for anomalies.				

4.2 High Risk Findings — Action Required Within 7 Days

AF-004	Privilege Creep	High	Open	TN-009
Employee: Ravi Nair — Finance Manager, Finance Systems Affected: CoreBanking Description: Transitioned from Engineering to Finance in 2022. CoreBanking access was elevated to Admin and prior Engineering entitlements were never reviewed or revoked. Has accumulated permissions across two roles exceeding what either position requires. Recommended Action: Conduct a full access review. Revoke all Engineering-era entitlements. Downgrade CoreBanking to Read/Write maximum. Implement a role-change access review procedure.				
AF-005	Excessive Privilege — PoLP Violation	High	Open	TN-024
Employee: Patrick Nguyen — Junior IT Support, IT Support Systems Affected: CoreBanking, HR Portal, GitHub Enterprise, AWS Console, Jira Description: Junior IT Support staff holds Admin access across all six systems, identical to the Senior IT Administrator. Violates the Principle of Least Privilege and creates unnecessary risk from an inexperienced user with unrestricted system control. Recommended Action: Immediately restrict to Read Only or Read/Write on non-critical systems. Remove CoreBanking and HR Portal access. Define a formal access tier matrix for IT Support roles.				
AF-006	Excessive Privilege — PoLP Violation	High	Open	TN-008
Employee: Sarah Kim — Junior Developer, Engineering Systems Affected: AWS Console Description: Junior Developer holds Admin access to the AWS Console. Cloud infrastructure admin rights should be restricted to senior engineers and DevOps roles. Accidental misconfiguration or account compromise could cause significant infrastructure damage. Recommended Action: Downgrade AWS Console to Read Only immediately. Require formal approval for Admin-level cloud access. Review any infrastructure changes made under this account.				

AF-007	Excessive Privilege — PoLP Violation	High	Open	TN-018
Employee: Zara Ahmed — Intern, Engineering Systems Affected: CoreBanking, HR Portal, AWS Console, GitHub Enterprise Description: Engineering Intern holds Read/Write to CoreBanking and AWS Console, and Read Only to the HR Portal. Interns should have the most restricted access profile of any role. No business justification exists for financial or cloud infrastructure access. Recommended Action: Remove CoreBanking and AWS Console access. Remove HR Portal access. Restrict GitHub to Read Only under supervisor oversight. Define a formal Intern Access Policy.				
AF-008	Unauthorised Access — Role Policy Violation	High	Open	TN-015
Employee: Oscar Fernandez — Sales Executive, Sales Systems Affected: CoreBanking Description: Sales Executive holds Read Only access to CoreBanking. The Sales department has no business requirement for payment system access per TechNova policy. This known breach was noted in the access register with no recorded remediation. Recommended Action: Remove CoreBanking access immediately. Investigate how this access was provisioned. Update provisioning workflows to block Sales department CoreBanking access by default.				
AF-009	Unauthorised Access — Data Privacy Violation	High	Open	TN-025
Employee: Amara Osei — Marketing Intern, Marketing Systems Affected: HR Portal Description: Marketing Intern holds Read/Write access to the HR Portal, which contains sensitive employee personal data including salaries and personal identification. No business justification exists. Likely violates GDPR data minimisation principles. Recommended Action: Remove HR Portal access immediately. Review audit logs for any employee data accessed. Notify the Data Protection Officer. Implement HR Portal access restrictions by department.				

4.3 Medium Risk Findings — Action Required Within 30 Days

AF-010	Overdue Access Review	Medium	Open	TN-023
Employee: Elena Vasquez — Sales Manager, Sales Systems Affected: CoreBanking Description: Last access review conducted June 2022, over 18 months prior to this audit. Holds Read/Write CoreBanking access not validated against her current role. ISO 27001 and SOC 2 both mandate access reviews at minimum annually. This is a compliance gap. Recommended Action: Conduct an immediate access review. Verify whether CoreBanking access is still required for her role. Update the review schedule to ensure full annual compliance.				
AF-011	Overdue Access Review — New Hire	Medium	Open	TN-005
Employee: Daniel Cruz — Junior Accountant, Finance Systems Affected: CoreBanking Description: Joined June 2023. Last access review at onboarding only. CoreBanking Read/Write access has not been validated since initial provisioning. New hire access should be reviewed at 30, 60, and 90 days post-joining as a minimum. Recommended Action: Conduct an immediate access review. Implement a 30/60/90-day new hire access review cadence as standard procedure going forward.				
AF-012	Excessive Privilege — Admin Overreach	Medium	Open	TN-017
Employee: Ben Carter — IT Administrator, IT Support Systems Affected: CoreBanking, HR Portal Description: IT Administrator holds Admin access to CoreBanking and the HR Portal. IT support functions do not require administrative rights over financial transaction systems or employee personal data. Creates an unnecessary insider threat risk. Recommended Action: Remove CoreBanking Admin access. Downgrade HR Portal to Read Only with access logging enabled. Define a formal IT Administrator access scope policy.				

5. Recommendations and Remediation Roadmap

Beyond the immediate remediation actions listed per finding, TechNova Inc. should implement the following process improvements to prevent recurrence and achieve a stronger IAM posture.

5.1 Immediate — Within 48 Hours

- Disable all accounts for terminated employees TN-011 (Kevin Okafor) and TN-022 (Yuki Tanaka) across all systems.
- Downgrade CoreBanking access for TN-021 (Rohan Desai) to Read Only and implement a secondary approver for all payment transactions.
- Rotate all AWS credentials associated with TN-022 and conduct a CloudTrail log review.

5.2 Short Term — Within 7 Days

- Conduct a full access review for all High risk findings (AF-004 through AF-009).
- Remove CoreBanking access from all Sales department users — no business justification exists.
- Remove HR Portal access from all Marketing department users — data privacy risk.
- Define and publish a formal Intern Access Policy limiting access to Jira and Slack only unless otherwise approved.

5.3 Medium Term — Within 30 Days

- Implement a mandatory 30/60/90-day access review cadence for all new hires.
- Conduct access reviews for all employees whose last review date exceeds 12 months.
- Define a formal access tier matrix for IT Support distinguishing Junior, Senior, and Administrator entitlements.
- Implement a role-change access review process — prior entitlements must be revoked before new ones are granted.

5.4 Long Term — Within 90 Days

- Implement automated access provisioning and deprovisioning workflows integrated with the HR system to eliminate orphaned accounts.
- Adopt a formal access review platform or schedule quarterly access certification campaigns across all departments.
- Define and document a company-wide RBAC policy with a role catalogue specifying permitted access levels for each role and system.
- Engage an external assessor to conduct a SOC 2 Type II readiness review, using the findings of this audit as a baseline.

6. Conclusion

This IAM audit has identified significant access control deficiencies across TechNova Inc.'s user population. The presence of active terminated employee accounts, a Segregation of Duties conflict in the Finance team, and widespread Least Privilege violations in junior and intern roles represent material security and compliance risks that require prompt remediation.

The three Critical findings — two orphaned accounts and one SoD conflict — must be treated as immediate priorities. Left unaddressed, they expose TechNova to regulatory non-compliance, financial fraud risk, and potential unauthorised access by former employees.

The broader pattern of access violations indicates that TechNova does not currently have a consistent, enforced IAM policy. The recommendations in Section 5 are designed to address not just the individual findings, but the underlying process gaps that allowed them to occur.

Implementing these recommendations will significantly improve TechNova's security posture and position the organisation for compliance with ISO 27001, SOC 2, and GDPR obligations.

Prepared By	Report Status
IAM Analyst — TechNova Internal Audit June 2025	Final — Issued for Management Review